STUDENT NAME: Ebere Emilia Ikechukwu

STUDENT ID: 2025/GCR/12707

Official email: gcr2512707@students.icdfa.edu.ng

Scenario: Northbridge Skills Institute

EXECUTIVE SUMMARY

At 08:45 WAT on Day 0, Northbridge Skills Institute declared a high severity cyber incident with potential to become critical. E06 confirms mass file changes on FIN-PC07, lock files and a ransom note in FS01 shared folder. E07 confirms learners cannot access materials or submit assignment through the learning portal. Earlier evidence shows a possible malicious attachment (E01), an unfamiliar Microsoft 365 sign-in (E02), unusual privileged activity by svc_backup (E03). 1.2 GB outbound HTTPS transfer from FIN-PC07 (E04), all these observations justify investigating both ransomware and possible data exfiltration but that does not prove who attacked the institute or personal data was stolen.

Immediate priorities are to contain affected systems without destroying volatile evidence, protect privileged and cloud identities, preserve logs, stop suspicious outbound traffic and available backups are trustworthy. The 11:00 online examination must not be restored onto an unverified environment merely to meet the scheduled time, management should approve a controlled continuity decision including postponement or an alternative assessment method if safe access cannot be validated.

Incident assessment and governance

Task 1: Incident classification and initial assessment

1.1 Evidence-based incident timeline

Time (WAT)	ID	Confirmed observation	Working hypothesis/ uncertainty	Next validation
Day −1, 16:40	E01	Finance officer opened unexpected payroll attachment on FIN-PC07, malicious execution is unverified.	Possible phishing or malware entry or execution may have been blocked	Endpoint process, obtain original email, attachment
Day 0, 01:15	E02	Finance officer signed into Microsoft 365 from unfamiliar IP and new device, MFA and user involvement unknown.	Possible stolen credentials or token misuse	Review M365 sign-in, MFA, device, token, mailbox audit and conditional access records, verify user.
Day 0, 01:35	E03	svc_backup made remote administrator logons to FS01 and BAK01 outside usual schedule.	Possible attacker abuse of privileged service account	Correlate Windows Security logs, service/task

				records, backup
Day 0, 01:50	E04	FIN-PC07 uploaded 1.2 GB via HTTPS to unfamiliar cloud storage, content unknown.	Possible exfiltration, cloud sync, legitimate transfer or unrelated process	DNS/firewall logs, destination details, endpoint process and cloud audit evidence.
Day 0, 02:00	E05	Backup console reports FS01 and LMS01 jobs successful; recoverability and clean state unverified.	Job success may mean files were copied, not that data is restorable or uninfected.	Review logs, backup account activity, perform isolated restore test.
Day 0, 08:30	E06	EDR and helpdesk report mass file changes on FIN-PC07; FS01 folders contain. locked files and ransom note; family unconfirmed.	Ransomware activity is strongly indicated, scope and persistence are unknown.	Isolate affected hosts; preserve note, file samples, system logs
Day 0, 08:40	E07	LMS login page loads, but learners cannot open materials or submit assessments; LMS01 scope unknown.	Availability and integrity of learning services are impaired, possibly through FS01 dependency.	Check LMS, web, database, application and FS01 logs; test dependency and data integrity.
Day 0, 08:45	E08	FS01 incident contact list inaccessible, staff phones available, corporate email trust unverified.	Response coordination is impaired, attacker may or may not have accessed email.	Confirm phone /offline contacts, validate email/identity systems before relying on them.

1.2 Classification and severity

Incident type: Suspected ransomware / destructive malware incident with confirmed operational disruption, possible privileged-account misuse and a potential data-exfiltration or data-extortion component. A personal-data breach is a possibility requiring investigation, not a confirmed fact.

Severity	Proposed criteria	Application to this case
Critical	Confirmed or highly likely compromise across multiple critical services or identity/backup infrastructure	Escalate to Critical if evidence shows active spread to additional systems, BAK01 compromise that removes viable recovery, verify sensitive-data theft with severe impact.
High	Confirmed material impact to a critical business service or multiple key assets; active ransomware indicators; significant uncertainty about scope or data exposure	Initial rating: HIGH. E06 confirms encrypted/locked files on FIN-PC07 and FS01; E07 confirms examination-related learning disruption. E02–E04 and E03 create material identity

Medium	Contained incident affecting a non-critical asset, no material service interruption, no credible evidence of spread or sensitive-data exposure, recovery is straightforward.	Not appropriate at 08:45 because shared files and learning services are affected and scope is unknown.
Low	Isolated low-impact event with no confirmed compromise and negligible business impact.	Not appropriate because E06 and E07 show tangible impact.

Initial severity: HIGH, with immediate reassessment checkpoints at 09:15, 10:00 and whenever new evidence changes scope. The incident commander may raise the incident to CRITICAL without waiting for the next checkpoint if active spread, backup destruction, or confirmed broad data theft is identified.

1.3 Affected assets and CIA assessment

Asset / service	Status based on evidence	Confidentiality	Integrity	Availability	Priority
FIN-PC07	Confirmed mass file changes; outbound 1.2 GB transfer; suspected malicious attachment (E01, E04, E06).	Potentially affected: data transferred may or may not contain sensitive files.	High concern: mass changes and possible malware	High concern: endpoint may be unusable/unsafe.	P1: isolate and preserve
FS01	Confirmed locked files/ransom note in shared folders; svc_backup remote admin logon (E03, E06).	Potential exposure of shared learner/finance files is unconfirmed.	High concern: files encrypted/changed scope unknown.	High: shared content unavailable; LMS depends on FS01.	P1: contain and investigate.
LMS01	Portal page loads but materials and submissions fail (E05, E07).	Unknown; assess logs and data access.	Unknown; validate course material and submissions.	Confirmed service impairment.	P1 business service; restore only after validation.
BAK01	Unusual svc_backup remote administrator logon; network backups not immutable	Potential exposure of backup contents/credentials.	Potential tampering or deletion; not established.	Recovery capability at risk.	P1: restrict access and preserve logs

	; backup jobs reported success but untested (E03, E05).				
Microsoft 365 / identity	Unfamiliar sign-in/new device (E02); corporate email trust unverified (E08).	Potential mailbox or account data exposure.	Potential mailbox rules/session changes.	Possible identity/email disruption; not confirmed.	P1: secure account and validate tenant.
Learner/finance data	Held by institute; transfer contents unknown (E04).	Possible exposure, not proven.	Potential encryption or alteration where stored.	Learning materials/submissions unavailable (E07).	P1 investigation and privacy assessment.

1.4 Immediate priorities and investigation questions

- **Assess data exposure and reporting**: preserve outbound-transfer metadata and initiate a documented legal/privacy assessment without stating that theft occurred.
- **Contain active encryption and prevent lateral movement:** isolate FIN-PC07 and affected FS01 network paths; restrict BAK01 and the svc_backup account through an approved emergency change.
- **Protect identity:** disable/revoke sessions for the finance officer account if compromise is plausible; check MFA, device registration, mailbox rules, OAuth grants and privileged changes; reset credentials from a known-clean device.

Task 2: Incident Response Plan and Team Responsibilities

2.1 Policy and Plan Outline

Policy element	Northbridge policy / procedure
Mission	Protect learners, staff, data and essential institute operations; contain cyber incidents; preserve reliable evidence; restore services safely; meet applicable legal, contractual and regulatory duties.
Objectives	Detect and classify quickly; limit impact; maintain decision accountability; preserve evidence; communicate accurately; restore validated services; document lessons and reduce recurrence.
Scope	All endpoints, servers, network and backup infrastructure, Microsoft 365 identity/email, learning and finance services, data, staff, contractors and service providers.
Declaration	Incident commander declares a cyber incident when credible evidence indicates unauthorized access, malware, data loss, service disruption or material policy breach. E06 plus E07 meets the threshold for formal declaration at 08:45.
Activation	High severity: immediate phone-tree activation and executive notification. Critical: activate all response roles, external incident-

	response support and executive crisis management. Staff must not use potentially compromised email until verified.
Authority	Incident commander coordinates decisions. Security/IT lead may immediately isolate a host or network segment when ongoing harm is likely; notify the commander as soon as practicable. Business owner approves service priorities; restoration requires security validation and business acceptance.
Escalation	Escalate for spread, suspected data exfiltration, privileged/identity compromise, backup tampering, inability to recover, material learner impact, media interest or possible notification duties.
Documentation	Maintain a time-stamped incident log, evidence register, decision log, action tracker, communications copies, approvals, assumptions and impact notes. Use WAT and synchronized time sources where available.
Evidence handling	Use trained collectors where possible, record source, method, collector, time, hash after acquisition, secure location and every custody transfer. Restrict access to authorized response, legal/privacy and forensic personnel.
Review	Review the plan at least annually, after material infrastructure changes, after exercises and after incidents. Assign owners and due dates to corrective actions.
Business continuity	Activate continuity arrangements for learning delivery, exams, finance and communications. The academic owner decides the examination outcome with management; safety and integrity checks override schedule pressure.

2.2 CSIRT structure and authority

Role (fictional placeholder)	Primary responsibility	Decision authority / support
Incident Commander — Amina Bello, Operations Director	Declares incident, sets priorities, chairs briefings, approves business-impact decisions and escalations.	Accountable for overall incident coordination; escalates Critical incidents to Executive Director.
Security Lead — Daniel Okafor, Security Analyst	Leads triage, threat hunting, indicators, scope assessment, containment recommendations and security validation.	May direct emergency technical containment under delegated authority; documents evidence trade-offs.
IT Operations Lead — Chika Nwosu, IT Manager	Coordinates server/network/endpoint isolation, identity administration, backups and rebuilding.	Executes approved changes; obtains second-person review for high-risk changes where feasible.
Forensics Lead — External IR consultant (to be engaged)	Plans forensic acquisition, evidence preservation, timeline reconstruction and technical reporting.	Advises on acquisition order and evidence integrity; receives only necessary access.
Business Owner — Mariam Yusuf, Academic Services Lead	Assesses learning/exam impact, learner support, data validation and service acceptance.	Recommends exam continuity options and signs off business readiness after security approval.
Legal/Privacy Adviser — Tunde Adebayo, external counsel/privacy adviser	Assesses applicable law, contracts, evidence preservation, notification recipients and deadlines.	Advises on formal breach notification and privilege; legal conclusions must be confirmed for actual facts.

Communications Lead — Ifeoma Eze, Communications Officer	Prepares approved staff, learner, media and partner messages; monitors misinformation.	Publishes only approved messages via trusted channels.
Executive Sponsor — Executive Director	Approves extraordinary spending, external notifications where policy requires, and major service interruption decisions.	Accountable for risk acceptance outside delegated authority.
Service Provider Liaison — IT Manager	Coordinates ISP, cloud/M365, managed security, backup vendor and forensic support.	Obtains vendor logs, containment help and escalation SLAs.

2.3 RACI matrix

R = Responsible (does the work); A = Accountable (one role ultimately answerable); C = Consulted; I = Informed. Each activity has exactly one A and at least one R. A/R means one role performs and is accountable.

Activity	**Responsible (R)**	**Additional R / Consulted (C)**	**Accountable (A)**	**Informed (I)**
Detect and declare incident	Security Lead (A/R)	IT Ops; Helpdesk	Incident Commander; Business Owner	Executive Sponsor; Legal/Privacy
Analyse scope and severity	Security Lead (A/R)	IT Ops; Forensics Lead	Incident Commander; Legal/Privacy	Incident Commander; Legal/Privacy
Contain endpoints/network/identity	IT Ops Lead (R)	Security Lead (R)	Incident Commander (A); Forensics Lead	Business Owner; Communications
Collect and handle evidence	Forensics Lead (R)	Security Lead (R)	Incident Commander (A); Legal/Privacy	IT Ops
Stakeholder communication	Communications Lead (R)	Business Owner (R)	Incident Commander (A); Legal/Privacy	Learners; staff; Executive Sponsor
Assess legal/privacy reporting duties	Legal/Privacy Adviser (R)	Security Lead (R)	Executive Sponsor (A); Incident Commander	Communications; Business Owner
Approve restoration and service return	Business Owner (R)	IT Ops (R); Security Lead (R)	Incident Commander (A)	Executive Sponsor; Communications
Close incident and lessons learned	Incident Commander (A/R)	Security Lead; IT Ops; Business Owner	Legal/Privacy; Forensics	All staff; Executive Sponsor

2.4 Readiness improvement checklist

Improvement	Owner	Resources required	Readiness test / evidence
Maintain disconnected, encrypted and preferably immutable backups for critical data; separate backup admin identities.	IT Operations Lead	Backup storage, separate credentials, retention budget, offline copy.	Quarterly restore of FS01/LMS sample into isolated environment; record recovery time, integrity results and approver.
Create offline incident contacts and call tree; keep one controlled paper copy and one protected offline copy.	Incident Commander	Printed contact pack, alternate phone numbers, role-based contacts.	Twice-yearly call-tree test; target: 90% of critical roles acknowledge within 15 minutes.
Extend EDR/log coverage to servers and centralize logs for endpoints, identity, proxy, firewall, server and backup systems.	Security Lead	Server EDR license's, central log storage, retention and alert tuning.	Quarterly coverage review: confirm all critical servers and identity logs are visible; test an alert end-to-end.
\Harden svc_backup and other privileged accounts: least privilege, dedicated admin identities, MFA where supported, monitored access and credential rotation.	IT Operations Lead	Identity admin time, MFA, privileged access controls, service-account dependency review.	Monthly privileged-account review; alert test for out-of-schedule access; document service dependencies before rotation.
Create out-of-band communications and approved holding statements for learners, staff, media and providers.	Communications Lead	Phone tree, SMS/phone options, templates, approval matrix.	Tabletop test: publish approved internal message within 20 minutes without relying on corporate email.
Run quarterly tabletop exercises and annual recovery exercises; train staff on phishing and incident reporting.	Security Lead	Scenario materials, facilitator, staff time, vendor participation.	Attendance and scored exercise; close actions by agreed deadlines; phishing reporting rate tracked.

Task 3: Response Operations and Communication

3.1 Response playbook and evidence preservation

Time / stage	Action	Owner	Approval	Evidence to retain	Completion check
08:45–08:50 (first 5 min)	Declare HIGH incident; open incident log; name incident commander; establish phone bridge; tell staff	Incident Commander	No separate approval: declaration is within authority.	Initial helpdesk alert, E06/E07 copies, call log, incident log.	Incident ID created; roles acknowledged; all timestamps WAT.

	not to use corporate email for sensitive response coordination.				
08:45–08:55	Immediately isolate FIN-PC07 from network; preserve power if safe; do not delete files or run cleanup tools. Record any forced shutdown and reason.	IT Ops + Security Lead	Emergency isolation delegated; inform commander immediately.	EDR alerts, host name/IP, isolation time, operator and method; volatile capture if feasible without delaying containment.	EDR/network console confirms isolation; no further outbound traffic.
08:50–09:00	Restrict FS01 affected shares/network access; block lateral paths from FIN-PC07; consider segment-level containment if spread is observed. Preserve FS01 state and logs.	IT Ops Lead	Incident Commander informed; Security Lead recommends scope	Server logs, file metadata, ransom note, network config/change record	Test from isolated test endpoint; confirm affected share unavailable to normal users.
08:50–09:05	Disable or restrict svc_backup remote admin use; revoke active sessions and protect BAK01. Do not delete account or logs. Review dependencies before permanent rotation.	IT Ops + Security Lead	Incident Commander authorizes emergency privileged restriction.	M365/AD and Windows logon records; backup audit logs; approval record	No unauthorized backup admin activity: backup console access limited to named clean admin.
08:55–09:10	Secure finance officer M365 account: revoke sessions/tokens as appropriate, reset credentials from known-clean device, inspect MFA/device registration, mailbox rules, app grants and sign-in history.	Security Lead + IT Ops	Emergency identity containment delegated; commander informed.	Sign-in and audit exports, before/after account state, admin action logs.	No suspicious sessions; new credentials protected; user verified out-of-band.
09:00–09:15	Preserve key logs and artifacts: proxy/DNS/firewall, EDR, Windows Security, M365	Security Lead / Forensics Lead	Forensics lead directs collection; legal consulted on scope.	Read-only exports or forensic images as appropriate; collector, time,	Evidence register completed; exports opened only

	audit, backup console, email and LMS/FS01 logs. Record retention windows and source clock offsets.			hash and storage record.	on working copies; hash verification documented
09:00–09:20	Block known suspicious destination at proxy/firewall after recording indicators; review other hosts communicating with it. Do not assume destination alone proves exfiltration.	Security Lead + IT Ops	Incident Commander approves broad blocking if material business impact.	Proxy logs, destination/domain/IP, rule change and rollback record.	Traffic blocked; affected connections searched across available logs.
09:05–09:25	Establish asset and scope map: FIN-PC07, FS01, LMS01, BAK01, Microsoft 365, identity, adjacent endpoints and admin tools. Hunt for encryption, remote logons, new accounts/tasks/services and backup tampering.	Security Lead	Incident Commander informed.	Asset list, EDR searches, server and identity audit results.	Known/unknown scope explicitly recorded; severity reassessed.
09:10–09:30	Notify executive sponsor, academic owner, legal/privacy adviser, communications and service providers using trusted phone channels. Request external IR/forensics and backup support.	Incident Commander	Within incident declaration authority, external spend per policy.	Call notes, recipients, time, requested support and approvals.	Required roles reached; contact failures escalated via alternate numbers.
09:15–09:35	Assess exam continuity options. Check whether a separate clean service or supervised alternative can be prepared safely; do not reconnect compromised	Academic Owner + Security Lead	Executive Sponsor approves postponement/alternative; security must validate any technical workaround.	Service dependency map, test results, decision rationale, learner-impact estimate.	Decision recorded by 09:35 where possible; learner message ready.

	systems or use unverified backup.				
09:20–10:00	Test backup recoverability only in isolated recovery environment. Start with a copy/snapshot and preserve original backup state. Check backup catalog, timestamps, access logs and integrity.	IT Ops + Forensics	Incident Commander approves isolated test; no production overwrites.	Backup job logs, snapshot metadata, test restore logs and integrity reports.	Pass/fail recorded; source backup remains preserved; no connection to production network.
10:00–12:00	Perform expanded threat hunt and forensic analysis; identify initial access, persistence, privilege changes, data accessed and likely scope. Obtain provider logs before retention expires.	Security/Forensics	Commander approves scope; legal advises on sensitive data collection.	Timeline, queries, exported logs, images, malware samples where safely acquired.	Hypotheses updated with confidence level; severity re-evaluated.
12:00–18:00	Plan eradication: rebuild rather than merely clean hosts where compromise is confirmed; patch entry vector; remove persistence; rotate affected credentials and service secrets after dependency review.	IT Ops + Security Lead	Incident Commander approves remediation plan; business owner consulted.	Golden image version, patch list, account/secret rotation log, forensic findings.	Build checklist passed; credentials rotated; known persistence checks clean.
18:00–Day 1 08:45	Restore priority services into a clean, segmented environment from validated backups or rebuilt systems. Monitor closely and keep incident bridge active.	IT Ops; Business Owner	Security Lead validates technical controls; Incident Commander accountable for return decision.	Restore logs, hashes/checksums where applicable, data reconciliation, security test and monitoring alerts.	Acceptance criteria below passed; business owner signs service acceptance; no unresolved critical alert.

3.2 Two Difficult Decisions

A. Containment Versus Evidence Preservation

The primary decision is to isolate FIN-PC07 immediately because E06 shows mass file changes and E04 shows a suspicious large outbound transfer. Isolation can stop further encryption and outbound communication. Before isolation, if this can be done within moments and without increasing risk, the Security Lead should record volatile indicators, active connections and current EDR state. If active spread is occurring, containment takes priority over a perfect capture. Do not power off by default: a shutdown can destroy volatile memory evidence. If network isolation is not feasible and encryption is actively spreading, emergency shutdown may be justified. Record who authorized it, time, method, expected evidence loss and business impact. Preserve the device and do not reimage it until forensic needs are considered.

B. Examination Access while Backup Safety is Uncertain

The 11:00 deadline is important but cannot justify reconnecting an untrusted system. E05 only reports successful backup jobs; it does not prove recoverability or cleanliness, and BAK01 may be at risk because svc_backup accessed it unusually (E03). The Security Lead and IT Operations Lead should only propose a temporary exam service after isolation, clean-build or trusted-source validation, identity controls, data integrity checks and a limited access test. If these conditions cannot be met, the Academic Services Lead should recommend postponement, or a supervised alternative and management should approve and communicate the decision. This protects assessment integrity and learner data while preserving a route to recovery.

3.3 Evidence register and custody

Evidence ID	Source	Proposed collection method	Collector	Date/time and time zone	Integrity check	Secure storage / access
EV-01	FIN-PC07 endpoint	Planned: acquire forensic image and, if feasible, volatile memory; export EDR timeline; preserve original payroll email/attachment separately.	Forensics Lead with Security Lead support	Day 0, after isolation; exact time to be recorded in WAT at collection.	Hash each acquired image/export using approved tool; record algorithm and values after acquisition; no hash available yet.	Encrypted evidence repository, restricted to named forensics/security /legal roles.
EV-02	FS01 server and ransom note/. locked files	Planned: export relevant Windows/security/file-share logs; capture ransom notes and representative metadata; image system/volume if approved.	Forensics Lead	Day 0; exact collection timestamp pending.	Hash exported files and images; compare hash after transfer; do not alter	Read-only master plus verified working copy; access log maintained.

					original evidence.	
EV-03	Microsoft 365 / identity audit	Planned: export sign-in, audit, mailbox-rule, device, MFA and session events through authorized admin process.	Security Lead	Day 0; preserve earliest available logs before retention expiry.	Hash export package; record export query, tenant, time range and operator.	Encrypted case folder; least-privilege access; legal/privacy access as needed.
EV-04	Proxy/DNS/firewall records for 1.2 GB transfer	Planned: export records around E04 and search same destination across environment; record destination and log time zone.	Security Lead / IT Ops	Day 0; exact collection timestamp pending.	Hash exports: preserve original logs where system permits; document clock differences.	Evidence repository; do not email logs to personal accounts.
EV-05	BAK01 backup console and job records	Planned: preserve job reports, admin audit logs, snapshot/catalog metadata and access history; isolated restore performed only on a copy.	IT Operations Lead with Forensics Lead.	Day 0; exact collection timestamp pending.	Hash exports and test artifacts; preserve original backup and metadata.	Backup admin restricted; evidence copy segregated from recovery copy.

3.4 Eradication and Recovery

- **Likely entry point:** the payroll attachment on FIN-PC07 (E01) is a lead, not a confirmed cause. Verify execution and initial access with email, endpoint, identity and network evidence. Also investigate M365 account compromise (E02), remote privileged activity (E03) and other possible entry vectors.
- **Persistence and broader compromise:** inspect scheduled tasks, services, startup/run keys, remote management tools, new accounts, privilege assignments, mailbox rules, OAuth grants, remote access, log clearing, backup settings and lateral movement. Search all endpoints and servers for matching indicators and suspicious account activity.
- **Credential security:** revoke suspicious sessions and tokens; disable/restrict compromised accounts; rotate passwords, service secrets and keys from a clean administrative workstation after mapping dependencies. Require MFA where supported, review recovery methods, and avoid reusing potentially compromised admin endpoints.
- **Eradication:** rebuild confirmed compromised endpoints/servers from trusted, patched images where practical; remove malicious persistence; patch the exploited weakness; reconfigure least privilege and EDR/logging; do not assume deleting the ransom note or decrypting files means the attacker is gone.
- **Backup selection:** treat both network backup routes as untrusted until validated. Prefer a known-good offline/disconnected backup from before suspected compromise, currently the last disconnected backup is Friday at 17:00 on Day −3. This is a candidate, not automatically a clean restore point. Validate provenance, integrity, restorability and content in an isolated environment.

Recovery

- **Restoration order:** (1) clean identity/admin control plane and essential network services, if affected; (2) core file service FS01 from a validated source; (3) LMS01 and its dependent content/data; (4) finance workstation/service; (5) other endpoints. Reorder if forensic findings show identity or another dependency is compromised. Do not restore BAK01 into production before securing its administration
- **Proposed recovery targets (planning assumptions, subject to business-owner approval):** critical learning portal RTO 8 hours from approved recovery start; finance workstation RTO 24 hours; full shared-file service RTO 48–72 hours. Proposed RPO: no more than 24 hours of learner submission data and finance records, but actual achievable loss depends on verified backups and transaction logs. Because the last disconnected backup is Day −3, actual data loss may exceed this target; never promise the target until validated.
- **Data validation:** compare file counts, checksums where available, application/database consistency, permissions, learner course materials, submission records and finance totals against trusted records. Test with representative users in an isolated segment. Review EDR and logs for recurrence and monitor elevated activity before reconnecting.
- Return-to-service acceptance: Security Lead signs off clean build, no known persistence, identity controls, EDR/logging, patching, segmentation and successful monitoring checks; IT Operations confirms performance and backup protection; Business Owner validates data and function; Incident Commander records final approval and any residual risk. If any critical criterion fails, keep the service isolated.

Task 4 — Communication and Escalation

4.1 Communication Matrix

Stakeholder	Trigger	Message owner	Channel	Approver	Update frequency
Executive Director / senior management	Incident declared; severity change; exam decision; recovery delay; suspected data exposure.	Incident Commander	Phone bridge: follow with approved written summary when email trusted.	Executive Director / delegated executive	Every 30 minutes for first 2 hours, then hourly or on material change.
IT/security and helpdesk	Immediately at declaration; isolation and evidence instructions; scope changes.	Security Lead	Staff phone tree / approved secure channel; avoid corporate email until validated.	Incident Commander	Every 15 minutes during first hour, then every 30–60 minutes.
Learners and parents/guardians where relevant	Confirmed learning disruption or exam status decision; practical instructions.	Communications Lead	Verified SMS, website status page hosted independently, official social channels and direct phone for accessibility needs.	Incident Commander with Academic Owner; Legal/Privacy consulted	Initial notice as soon as decision confirmed; update at stated time and on material change.
Academic staff / faculty	Learning portal impairment; examination continuity decision; manual process instructions.	Academic Services Lead	Phone tree and approved staff messaging channel.	Incident Commander	Every 30 minutes until exam plan is clear, then on change.

Cloud/M365, ISP, backup and managed service providers	Need for audit logs, containment, tenant security, backup preservation or expert support.	IT Operations Lead	Verified vendor support portal/phone; record case numbers.	Incident Commander for major scope or cost	At engagement, then per agreed SLA/when evidence requested.
Legal/privacy adviser	Potential personal-data exposure (E04); learner/finance records affected; media inquiry; possible formal notification.	Incident Commander	Phone: secure channel verified independently.	Executive Sponsor	Immediately, then at each material finding and before formal notification.
Journalists/ public	Media enquiry or misinformation; no speculation about theft or attribution.	Communications Lead	Approved holding statement by phone or official channel.	Incident Commander: Legal/Privacy consulted	Acknowledge promptly; substantive update only when verified; schedule next update.
Regulators/law enforcement/ insurers, if applicable	Legal assessment confirms trigger, contractual duty or need for assistance.	Legal/Privacy Adviser	Verified official contact route; documented formal channel.	Executive Sponsor or delegated authority	Within applicable legal/contractual deadline; no deadline assumed until jurisdiction and facts verified.

4.2 Executive Briefing

At 08:45 WAT on Monday, Northbridge Skills Institute declared a high-severity cyber incident following reports of mass file changes on FIN-PC07 and. locked files with a ransom note in FS01 shared folders. Learners can load the learning portal login page but cannot access materials or submit assessments. The 11:00 examination is therefore at risk. Earlier records show an unfamiliar Microsoft 365 sign-in, unusual remote administrator activity by svc_backup on FS01 and BAK01, and a 1.2 GB HTTPS upload from FIN-PC07 to unfamiliar cloud storage. These are significant indicators but they do not yet prove personal-data theft, identify the attacker or confirm the ransomware family. Backup job reports show success but recoverability and cleanliness remain unverified; the last disconnected backup dates to Day −3. Immediate actions are to isolate affected systems, restrict privileged access, preserve logs, assess wider compromise, and request specialist support. Approval is required for the examination continuity decision, external incident-response support and any formal external notification after legal/privacy review. Staff should use verified phone channels until corporate email is trusted. The next management update will be at 09:15 WAT or earlier if scope or severity materially changes.

4.3 Learner Notice

Northbridge Skills Institute is investigating a technical security incident affecting access to the learning portal. At present, some learners may be unable to open course materials or submit assessments. We are taking steps to protect our systems and verify that learning services can be used safely. The status

of the 11:00 examination is under urgent review, please do not assume it is proceeding or cancelled until you receive a confirmed update through an official institute channel. Check the institute's verified status page or official SMS notice and keep any work you have already completed. Do not open unexpected messages or attachments claiming to provide exam links, and do not send passwords or verification codes to anyone. We will provide the next update by 09:45 WAT, even if the investigation is ongoing. We apologize for the disruption and will share verified information as it becomes available.

4.4 Legal/Privacy Assessment and Escalation

The Legal/Privacy Adviser should establish the applicable jurisdiction, whether the institute is a data controller or processor for each dataset, the categories and number of people potentially affected, the types of personal data involved, whether access/exfiltration is supported by evidence, likely harm, contractual duties and any cross-border processing or provider responsibilities. E04 is a suspicious transfer but does not identify its content. Therefore, the institute must not announce that learner data was stolen without corroboration. Conversely, absence of proof at the initial stage is not proof that no exposure occurred.

For a Nigeria-based institute, the adviser should consult the Nigeria Data Protection Act 2023 and current Nigeria Data Protection Commission guidance, confirm whether a personal data breach has occurred, identify the correct recipients and calculate any applicable deadline from the legally relevant trigger. This draft intentionally does not state a fixed deadline because the facts, role, and applicable provisions must be confirmed against the authoritative text and current guidance. Operational service notices are not a substitute for any formal breach notification. Preserve the reasoning, evidence reviewed, notification decision, approver and timestamps.

Escalate immediately to the Executive Sponsor if there is verified sensitive-data exfiltration, broader identity compromise, backup destruction, an inability to restore critical learning services, a material increases in affected assets, or a credible threat of publication. Escalate to legal/privacy before making public claims about data exposure or issuing formal notifications.

Task 5 Tabletop Exercise and Improvement Plan

5.1 Exercise design

Exercise time	Activity / inject	Expected focus
00–10 min	Brief scenario, roles, authority, severity and first 60-minute actions.	Declare HIGH; isolate FIN-PC07/FS01; secure BAK01 and identities; activate phone tree; preserve evidence.
Minute 10	Management asks to reopen the learning portal before 11:00 even if the latest backup is unverified.	Refuse unsafe restoration; present tested clean environment/alternative options; management makes documented exam decision.
Minute 20	Attacker claims to hold all 1,800 learner records and threatens publication in 12 hours; screenshot authenticity unknown.	Preserve message and metadata; avoid confirming claim; investigate exfiltration; legal/privacy assessment; prepare holding statement.

Minute 35	Test restoration of latest network backup fails with unreadable snapshot error.	Keep backup preserved; stop repeated writes; test disconnected backup in isolated environment; engage vendor; reassess RTO/RPO.
Minute 45	Social media says exam is cancelled; journalist asks whether learner information was exposed.	Correct misinformation using approved channels; state only verified impact; no speculation; designate spokesperson.
Minute 50 (additional inject)	Phone-tree contact for the IT Manager fails and corporate email shows an unfamiliar mailbox rule.	Use alternate contact; investigate email integrity; revoke suspicious sessions/rule only after preserving audit evidence; record escalation delay
Minute 55–60	Hot wash: compare actions to criteria, record owners and due dates.	Confirm decisions, evidence gaps, action owners, review date and communication schedule.

5.2 Measurable Success Criteria

Inject	Decision	Owner	Rationale	Communication	Effect
Minute 10 — pressure to reopen	Keep portal offline unless a clean, isolated recovery path passes validation; recommend postponement or approved alternative if not ready.	Incident Commander: Executive Sponsor approves business decision.	E05 does not prove backup cleanliness or restorability; E03 creates backup concern; safety and assessment integrity take precedence.	Phone briefing to management; prepare learner notice and update time.	Avoids reintroducing malware; may delay examination; creates a documented continuity decision.
Minute 20 — extortion claim	Treat screenshot as an unverified lead; preserve original message and screenshot metadata; investigate access and transfer records; involve legal/privacy.	Security Lead; Legal/Privacy leads reporting assessment.	Claim may be bluff, recycled data, or genuine; E04 alone does not prove contents.	Management update: possible exposure under investigation; no public confirmation of theft.	Preserves evidence and avoids unsupported claims; investigation scope may expand.
Minute 35 — failed backup test	Stop using the failing snapshot; preserve logs; test last disconnected	IT Operations Lead; Incident Commander approves revised plan.	A failed test increases recovery uncertainty: it does not prove every	Management receives recovery-risk update; academic owner prepares contingency.	Prevents destructive retries and keeps alternatives

	backup in isolated lab; contact backup vendor; revise recovery estimate.		backup is unusable.		open; likely extends RTO.
Minute 45 — media and social post	Issue approved factual holding statement; correct exam misinformation via verified channels; do not claim data is or is not stolen.	Communications Lead: Incident Commander approves; Legal consulted.	Operational disruption is confirmed; data theft is not established.	Official status page/SMS/verified social account; journalist receives holding statement.	Reduces confusion and avoids speculation; scheduled updates continue.
Minute 50 — unreachable IT Manager and suspicious mail rule	Use alternate phone contact; preserve M365 audit evidence; have authorized clean admin inspect and remediate the rule and sessions.	Security Lead; Incident Commander accountable.	Possible email compromise means corporate email remains untrusted; one failed contact tests continuity.	Out-of-band phone bridge; alert executive sponsor and communications lead.	Maintains command and avoids relying on potentially compromised email; adds identity investigation work.

5.3 Simulated Evaluation and Improvement Plan

Priority	Improvement action	Owner	Target completion	Measurable completion evidence
P1	Build and test offline incident contact pack with two contacts per critical role and escalation fallback.	Incident Commander	Within 7 days	Signed contact list; call-tree test with ≥90% acknowledgement in 15 minutes.
P1	Restore-test disconnected backup and document clean recovery point, data integrity, RTO/RPO and failure procedure.	IT Operations Lead	Within 14 days	Successful isolated restore report; file/data reconciliation; executive-approved recovery targets.
P1	Expand EDR/logging to all servers and centralize M365, proxy, server and backup logs.	Security Lead	Within 30 days	Coverage report showing all critical assets; alert test and retained log export.
P1	Implement least-privilege backup	IT Operations Lead	Within 21 days	Access review, tested alert,

	administration, separate accounts, MFA where supported, and alerting on unusual access.			approved service-account dependency map.
P2	Create approved learner/media holding statements and independently hosted status/phone/SMS fallback.	Communications Lead	Within 10 days	Exercise demonstrates approved notice within 10 minutes and a clear next-update time.
P2	Run quarterly ransomware/continuity tabletop and track corrective actions to closure.	Security Lead	First repeat exercise within 45 days	Attendance, scored criteria, action tracker and evidence links.

Post-incident review deadline: within 10 business days after the incident is declared contained and critical services are stable or sooner if management policy requires. The Incident Commander chairs the review, Security, IT, Academic Services, Legal/Privacy, Communications and relevant vendors contribute. The Executive Sponsor closes actions only after owners provide measurable evidence, overdue P1 actions are escalated to executive management.

Task 6: Case Study Analysis and Critical Reflection

The healthcare ransomware case shows how important it is for an organization to respond quickly when a cyberattack occurs. Three strengths of a good incident response are early detection, teamwork and restoring the most important services first. Detecting the attack early can help prevent it from spreading to other systems. Teamwork is also important because the IT team cannot handle every part of the incident alone. Management, security, legal and communication teams need to work together. In addition, restoring essential services first helps the organization continue its most important activities while other systems are being fixed.

However, there are some challenges to consider. One is the pressure to restore systems quickly, which may lead to mistakes if the organization has not confirmed that the threat has been contained. Another challenge is determining whether sensitive information has been stolen. Even when there is no obvious sign of data theft, it does not automatically mean that no information was accessed or copied.

I would apply two lessons from this case to the Northbridge Skills Institute plan. First, affected computers and accounts should be isolated where necessary to stop the attack from spreading. At the same time, relevant evidence should be preserved for investigation. Second, clear responsibilities should be assigned to the incident response team. This would help everyone understand who makes decisions, who handles the technical work and who communicates with staff and other stakeholders.

Restoring critical systems within 72 hours is not the same as completing full recovery within seven days. The first target should be to bring back essential services safely. Before doing so, the team must confirm that backups are clean and that restored systems are secure. Full recovery may take longer because other systems still need to be checked, data verified, passwords reset and security controls tested.

Before stating that no patient data was stolen, the investigation team would need to examine system logs, network activity, login records, security alerts and evidence of unusual data transfers. Any missing logs or gaps in monitoring should also be considered. Without enough evidence, the organization should avoid making a definite claim.

After the tabletop exercise, I would change the Northbridge recovery plan so that systems are not restored simply because a deadline is approaching. The incident lead and technical team should first confirm that the threat is contained, backups are safe and restored systems have passed security checks. This would help Northbridge recover as quickly as possible without creating further risks.

References

1. International Cybersecurity and Digital Forensics Academy (ICDFA). (n.d.). Incident Response Planning Assignment: GRC105 Incident Management and Business Continuity, Week 20, pp. 1–6. Course assignment brief supplied by the student. *Assignment-specific scenario, evidence IDs, task requirements and marking rubric.*
2. International Cybersecurity and Digital Forensics Academy (ICDFA). (n.d.). Incident Response Planning, GRC105 Week 20 teaching deck, slides 1–18. [Required source; slide 16 not supplied with the assignment brief.] *Required for Task 6 case analysis; insert the course deck details when available.*
3. National Institute of Standards and Technology. (2025). SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile. https://csrc.nist.gov/pubs/sp/800/61/r3/final *General incident response risk-management guidance. NIST states Rev. 3 aligns incident response with CSF 2.0 and supersedes Rev. 2.*
4. Cybersecurity and Infrastructure Security Agency and partners. (2023). #StopRansomware Guide. https://www.cisa.gov/resources-tools/resources/stopransomware-guide *Ransomware preparation, offline backup, isolation, evidence preservation, threat hunting and recovery recommendations.*
5. *Federal Republic of Nigeria. (2023). Nigeria Data Protection Act, 2023. Nigeria Data Protection Commission. https://ndpc.gov.ng/ Primary legal source to be reviewed by the Legal/Privacy Adviser when determining whether a formal personal-data breach notification is required*